

Nom : **DIESSE ALFRED LANDRY**

Date : LIRT 2025/2026

CHAPITRE 4

■ TP 4.1 – Détection d’attaques avec un IDS/IPS (Suricata sur pfSense)

1. Objectif du TP

L’objectif de ce TP est de mettre en place un système de détection et de prévention d’intrusion (**IDS/IPS**) avec **Suricata** sur **pfSense** afin de :

- surveiller le trafic réseau en temps réel ;
- détecter les comportements suspects ;
- générer des alertes de sécurité ;
- bloquer automatiquement certaines attaques.

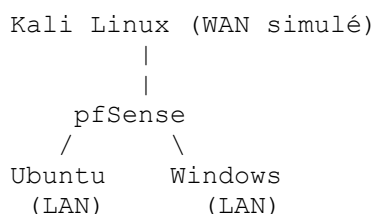
Dans ce laboratoire :

- **Ubuntu** et **Windows** sont placés sur le réseau interne (**LAN**) ;
- **Kali Linux** est placé sur le réseau externe (**WAN simulé**) ;
- **pfSense** agit comme pare-feu central.

Toute communication passe donc par pfSense, ce qui en fait un point stratégique d’analyse.

2. Architecture réseau

Topologie utilisée



Rôle des machines

Machine	Rôle
Kali Linux	Machine d'attaque
Ubuntu	Serveur cible
Windows	Poste utilisateur
pfSense	Pare-feu + IDS/IPS

3. Installation de Suricata

Connexion à l'interface web pfSense :

`https://192.168.1.1`

Navigation :

System → Package Manager → Available Packages

Recherche du paquet :

Suricata

Installation du package.

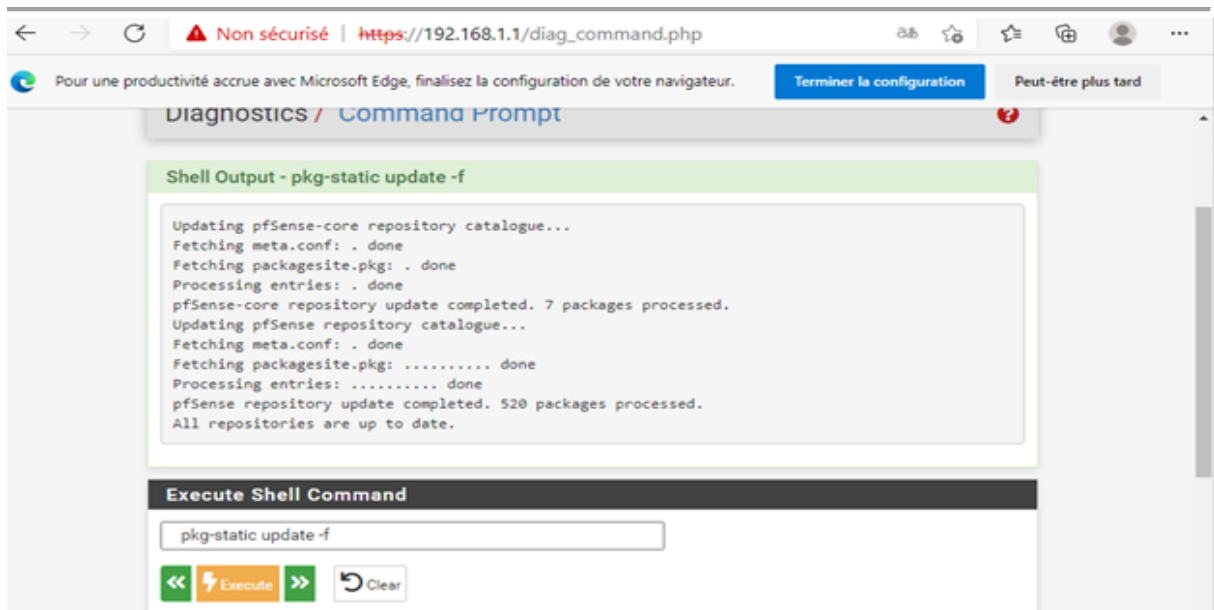
Explication

Suricata ajoute à pfSense une capacité d'analyse approfondie des paquets réseau.

Contrairement à un simple pare-feu qui filtre selon :

- IP
- port
- protocole

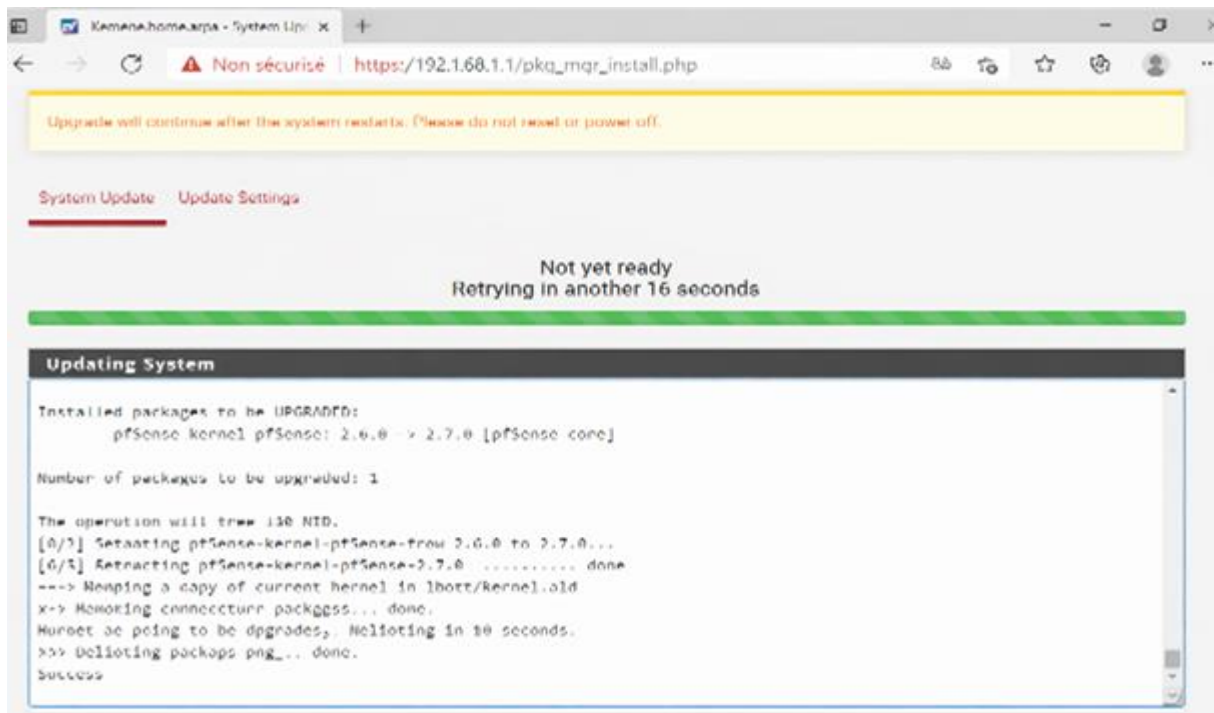
Suricata inspecte le contenu réel des paquets.



- Téléchargement de suricata via l'interface pfsense

Capture 1 : Installation de Suricata

- Mise à jour



4. Activation de Suricata sur le LAN

Navigation :

Services → Suricata → Interfaces

Ajout d'une nouvelle interface :

- cliquer sur **Add**
- sélectionner **LAN**

Puis sauvegarder.

Pourquoi surveiller le LAN ?

La plupart des attaques se propagent après intrusion initiale.

Surveiller le LAN permet donc de détecter :

- scans internes ;
- mouvements latéraux ;
- exploitation de services internes.

Capture d'écran : Configuration de Suricata sur l'interface LAN

The screenshot displays the Suricata configuration page in pfSense. The top navigation bar includes links for Interfaces, Global Settings, Updates, Alerts, Blocks, Files, Pass Lists, Suppress, Logs View, Logs Mgmt, SID Mgmt, and Sync. The 'Interfaces' link is highlighted. Below this, the 'IP Lists' section is visible. The 'LAN Settings' link is also highlighted. The 'General Settings' section is expanded, showing the following configuration:

- Enable:** A checkbox is checked, with the text: "Checking this box enables Suricata inspection on the interface."
- Interface:** A dropdown menu is set to "LAN (em1)". Below it, a note states: "Choose which interface this Suricata instance applies to. In most cases, you will want to choose LAN here if this is the first Suricata-configured interface."
- Description:** A text field contains the value "LAN". Below it, a note states: "Enter a meaningful description here for your reference. The default is the pfSense interface friendly description."

The 'Logging Settings' section is partially visible at the bottom, showing a checkbox for "Send Alerts to System Log" which is unchecked. A note below it states: "Suricata will send Alerts from this interface to the firewall's system log." A small note at the bottom of the page reads: "NOTE: the Snort2 ruleset does not automatically truncate oversized messages to 4096 bytes now."

Capture 2 : Interface LAN ajoutée dans Suricata

5. Activation des règles de détection

Navigation :

Services → Suricata → Global Settings

Activation :

Enable ET Open Rules

Ensuite :

Updates → Update Rules

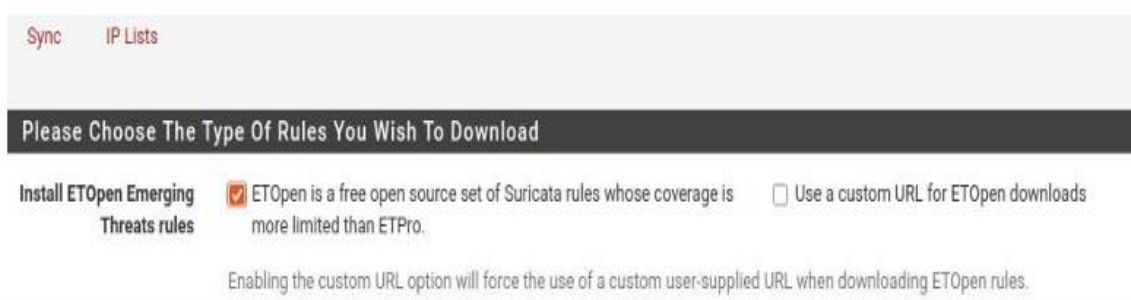
Explication

Les règles sont des **signatures d'attaque**.

Elles permettent de reconnaître :

- scans Nmap ;
- brute force ;
- exploits connus ;
- signatures malware.

Les règles **Emerging Threats Open** fournissent une base gratuite de signatures.



Capture 3 : Activation ET Open Rules

6. Démarrage de Suricata

Navigation :

Services → Suricata → Interfaces

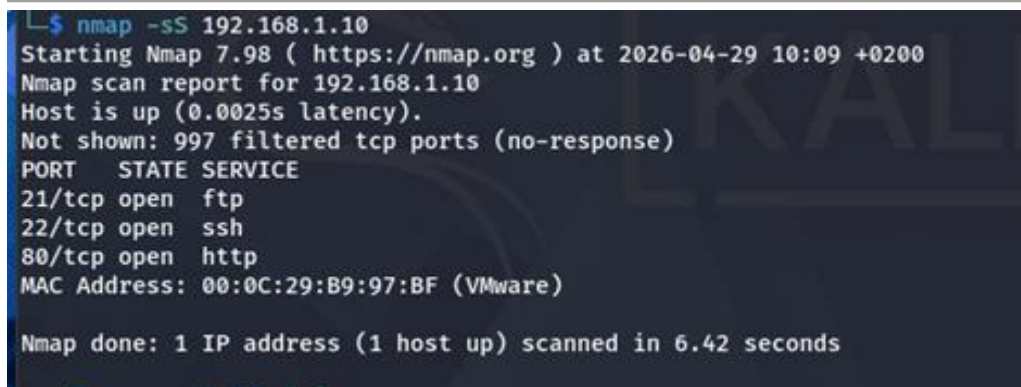
Activation :

- cocher **Enable**
- démarrer Suricata sur interface LAN.

Vérification :

Suricata doit afficher :

Running



```
└─$ nmap -sS 192.168.1.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-29 10:09 +0200
Nmap scan report for 192.168.1.10
Host is up (0.0025s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 00:0C:29:B9:97:BF (VMware)

Nmap done: 1 IP address (1 host up) scanned in 6.42 seconds
```

Capture d'écran : Suricata actif et détection du scan Nm

7. Génération d'une attaque (scan Nmap)

Depuis Kali Linux :

```
nmap -sS 192.168.1.10
```

Cible :

- Ubuntu : 192.168.1.10

But

Simuler un scan SYN stealth.

Ce type de scan est souvent utilisé pour :

- reconnaissance réseau ;
 - découverte de ports ouverts.
-

```
└─$ nmap -sS 192.168.1.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-29 10:09 +0200
Nmap scan report for 192.168.1.10
Host is up (0.0025s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 00:0C:29:B9:97:BF (VMware)

Nmap done: 1 IP address (1 host up) scanned in 6.42 seconds
```

: Exécution Nmap depuis Kali

8. Analyse des alertes

Navigation :

Services → Suricata → Alerts

Observation :

Apparition d'alertes liées au scan.

Exemple d'alerte :

ET SCAN Nmap Scripting Engine User-Agent Detected

ou

ET SCAN Potential Nmap Scan

Interprétation

Suricata détecte :

- fréquence anormale des paquets ;
- comportement de scan ;
- signatures connues.

Même sans blocage, une alerte est générée.

Save Settings	 Save	☒ Refresh
	Save auto-refresh and view settings	Default is ON

Alert Log View Filter					
Last 250 Alert Entries. (Most recent entries are listed)					
Date	Action	Pri	Proto	Class	Src
04/29/2026 10:13:56		3	UDP	Generic Protocol Command Decode	192.168.1.10  
04/29/2026 10:13:56		3	UDP	Generic Protocol Command	192.168.1.10  

Suricata détecte immédiatement le comportement anormal et génère des alertes correspondant

Capture 7 : Alertes générées

9. Simulation d'une attaque avancée

Depuis Kali :

```
msfconsole
```

Puis lancement d'un exploit Metasploit déjà utilisé.

Exemple :

```
use exploit/linux/samba/is_known_pipename
```

ou autre module SMB.

Observation

Retour dans :

```
Services → Suricata → Alerts
```

Des alertes critiques apparaissent.

Exemples :

- exploit attempt
 - shellcode detected
 - suspicious payload
-

- hôte partiellement inaccessible.

Alert and Block Settings	
Block Offenders	☒ Checking this option will automatically block hosts that generate a Suricata alert.
IPS Mode	Legacy Mode Select blocking mode operation. Legacy Mode inspects copies of packets while Inline Mode inserts the Suricata inspection engine into the network stack between the NIC and the OS. Default is Legacy Mode. Legacy Mode uses the PCAP engine to generate copies of packets for inspection as they traverse the interface. Some "leakage" of packets will occur before Suricata can determine if the traffic matches a rule and should be blocked. Inline mode instead intercepts and inspects packets before they are handed off to the host network stack for further processing. Packets matching DROP rules are simply discarded (dropped) and not passed to the host network stack. No leakage of packets occurs with Inline Mode. WARNING: Inline Mode only works with NIC drivers which properly support Netmap! Supported drivers include: bnx2, cc, cxgbe, cxl, em, ena, ice, igb, igc, ix, ixgbe, ixl, lem, re, vmx, vtnet. If problems are experienced with Inline Mode, switch to Legacy Mode instead.
Kill States	☒ Checking this option will kill firewall states for the blocked IP. Default is Checked.
Which IP to Block	BOTH Select which IP extracted from the packet you wish to block. Choosing BOTH is suggested, and it is the default value.
Block On DROP Only	☐ Checking this option will insert blocks only when rule signatures having the DROP action are triggered. When not checked, any rule action (ALERT or DROP) will generate a block of the offending host. Default is Not Checked.
IP Pass List	default Choose the Pass List you want this interface to use. Addresses in a Pass List are never blocked. Select "none" to prevent use of a Pass List. The default Pass List adds Gateways, DNS servers, locally-attached networks, the WAN IP, VPNs and VIPs. Create a Pass List with an alias to customize whitelisted IP addresses. This option will only be used when block offenders is on. Choosing "none" will disable Pass List generation.
Enable Passlist Debugging Log	☐ Checking this option will enable detailed Passlist operations logging to file /var/log/suricata/suricata_em144392/passlist_debug.log. Default is Not Checked.

Capture 10 : Activation Block Offenders

Scan perturbé/bloqué

11. Fonctionnement de Suricata

Suricata analyse :

1. paquets entrants ;
2. contenu ;
3. signatures.

Lorsqu'une règle correspond :

- alerte générée ;
- journalisation ;
- éventuellement blocage.

Exemple :

Un scan Nmap génère de multiples SYN rapides.

Suricata compare cela à une signature connue et déclenche une alerte.

12. Différence entre IDS et IPS

IDS	IPS
Détecte	Détecte + bloque
Surveillance passive	Action automatique
Génère alertes	Stoppe connexions

IDS

Observe et alerte.

IPS

Observe, détecte et bloque immédiatement.

13. Intérêt des signatures

Les signatures permettent :

- reconnaissance automatique d'attaques ;
- standardisation ;
- mise à jour continue.

Exemples détectés :

- Nmap
- brute force SSH
- SMB exploit
- malware traffic

Sans signatures, Suricata serait incapable d'identifier précisément les attaques.

14. Options avancées de Suricata

a) Types de règles

- alert

- pass
 - drop
 - reject
-

b) Niveaux de sévérité

- Low
 - Medium
 - High
 - Critical
-

c) Filtrage des alertes

Possibilité de filtrer par :

- IP source
- IP destination
- catégorie
- gravité

Cela facilite l'analyse SOC.

15. Compétences acquises

À la fin du TP, nous savons :

- installer Suricata ;
 - activer règles IDS ;
 - surveiller trafic réseau ;
 - détecter scans et exploits ;
 - passer en mode IPS ;
 - bloquer automatiquement certaines attaques.
-

16. Conclusion

Ce TP a permis de mettre en place une architecture de sécurité réaliste.

Nous avons vérifié que :

- un pare-feu contrôle les flux réseau ;
- un IDS analyse les comportements ;
- un IPS bloque automatiquement les attaques.

Les tests ont confirmé que les attaques réalisées précédemment sont détectables par Suricata.

Cette solution est proche des mécanismes utilisés dans les **SOC modernes** pour la supervision réseau et la réponse aux incidents.